



— AXE F · LES RELATIONS D'APPROBATION

La porte entre deux domaines, **restée ouverte**

Une approbation oubliée n'est pas un détail d'histoire : c'est un pont d'authentification que plus personne ne surveille.

Il y a sur votre forêt une relation d'approbation que personne ne sait vraiment expliquer. Elle date d'une fusion, d'un projet abandonné, d'un partenaire d'hier. On la laisse « parce qu'on ne sait pas ce qu'elle casserait ». Cette fiche montre pourquoi cette porte oubliée mérite, ce mois-ci, toute votre attention.

L'IDÉE REÇUE

« Cette vieille approbation avec l'autre domaine ? Un détail historique, ça ne nous concerne plus. »

En réalité — une relation d'approbation est un **pont d'authentification permanent**. Compromettre le domaine d'en face — souvent plus petit, plus ancien, moins surveillé — peut suffire à forger un accès chez vous, sans jamais toucher à votre périmètre.

Le sens de la flèche change tout



Une approbation a une direction. Croire qu'on « fait confiance » à un partenaire alors que c'est lui qui peut s'authentifier chez vous est l'erreur de lecture la plus fréquente — et la plus lourde de conséquences.

AU SOMMAIRE DE CETTE FICHE

1

Le déclic

L'idée reçue, l'analogie du double des clés, l'impact métier.

2

Le mécanisme

Le TGT inter-royaume, le SID History, le filtrage de SID.

3

La salle des machines

Vérifier, comprendre l'attaque, corriger et détecter.

1 NIVEAU 1 — POUR COMPRENDRE

Le déclic

Presque chaque forêt Active Directory un peu ancienne porte la même cicatrice : une relation d'approbation dont plus personne ne connaît l'histoire exacte. Elle est née d'une fusion d'entreprises, d'une filiale revendue, d'un projet commun avec un partenaire. Le projet s'est terminé ; l'approbation, elle, est restée.

On la regarde de loin, avec une vague méfiance, et on la laisse en place — « on ne sait pas ce que ça casserait de la retirer ». Cette prudence est compréhensible. Elle repose pourtant sur une image fausse de ce qu'est une approbation.

Nous imaginons une approbation comme une poignée de main : deux organisations qui « se font confiance », un accord poli et un peu abstrait. La réalité est beaucoup plus concrète. Établir une approbation, c'est **échanger un double des clés**.

« Une approbation, ce n'est pas une poignée de main : c'est un double de vos clés, remis à une maison dont vous ignorez si elle est bien gardée. »

POURQUOI ÇA COMPTE — L'IMPACT MÉTIER

Votre posture de sécurité ne s'arrête pas aux frontières de votre domaine : elle inclut, qu'on le veuille ou non, celle de tous les domaines auxquels vous êtes lié par une approbation. Vous pouvez avoir durci votre annuaire avec soin — comptes, délégations, permissions, PKI — et rester exposé par un domaine partenaire que vous n'administrez pas, que vous n'auditez pas, et dont vous ignorez peut-être jusqu'au responsable. Une approbation oubliée transforme la sécurité d'un tiers en votre propre angle mort. La première étape n'est pas technique : c'est de retrouver, et de comprendre, chaque pont qui sort de votre forêt.

Reprenons l'image. Deux entreprises partagent un même immeuble et décident de faciliter la circulation. Elles échangent un passe. Désormais, le service de sécurité de l'entreprise A reconnaît les badges émis par l'entreprise B : il les laisse entrer sans réémettre de badge, simplement parce qu'ils viennent d'une maison « de confiance ».

Tout va bien tant que l'entreprise B garde ses propres badges sous contrôle. Mais si la sécurité de B est défaillante — et B est souvent le domaine le plus ancien, le moins doté, le moins surveillé — alors quiconque compromet B peut se fabriquer un badge que *votre* service de sécurité, à vous, laissera passer. La confiance que vous avez accordée hier est devenue le maillon faible d'aujourd'hui.

2

NIVEAU 2 — LE FONCTIONNEMENT RÉEL

Le mécanisme

Quand deux domaines établissent une approbation, ils partagent un secret : une **clé d'approbation**, dérivée du mot de passe d'un compte spécial — le compte de confiance inter-domaine. C'est cette clé qui matérialise le « double des clés » de l'analogie. Lorsqu'un utilisateur du domaine A veut accéder à une ressource du domaine B, son contrôleur lui remet un **TGT inter-royaume**, chiffré avec cette clé partagée. Le domaine B le reçoit, le déchiffre, reconnaît qu'il vient d'un domaine de confiance — et accorde l'accès.

Au cœur de ce ticket se trouve une structure décisive : le **PAC**, qui transporte l'identité de l'utilisateur et la liste de ses SID — son SID principal, mais aussi tous ceux de ses groupes. C'est cette liste que le domaine B consulte pour décider des droits à accorder. Et c'est là qu'un attribut discret entre en scène : le **SID History**.

Le SID History — une commodité devenue une faille

Le SID History est un attribut prévu pour les migrations : quand un compte change de domaine, il conserve dans cet attribut ses anciens SID, afin de garder l'accès à ses anciennes ressources le temps de la transition. Utile. Mais le PAC transporte aussi ce SID History — et le domaine B l'honore comme le reste.



Le garde-fou existe, et il porte un nom : le **filtrage de SID** (SID filtering). Activé sur une approbation, il demande au domaine qui reçoit le ticket d'**écarter tout SID étranger à son partenaire légitime** — en particulier les SID injectés frauduleusement dans un SID History. C'est le vider qui, à l'entrée, retire de votre badge les autorisations que vous n'auriez jamais dû y inscrire. Sur les approbations modernes entre forêts, il est actif par défaut. Mais sur les approbations anciennes, intra-forêt, ou créées avec des options de compatibilité, il peut être absent — et c'est précisément là que le pont devient une autoroute.



Schéma 1 — L'injection de SID History : le filtrage de SID est le seul garde-fou sur le trajet.

SOUS L'ÉCORCE

« Nos domaines sont dans la même forêt — entre eux, pas besoin de se méfier. » — C'est l'angle mort le plus répandu. À l'intérieur d'une forêt, les approbations entre domaines **n'appliquent pas le filtrage de SID** : la forêt est considérée comme une seule frontière de sécurité, et tous ses domaines se font pleinement confiance. La conséquence est lourde : compromettre le plus négligé de vos domaines enfants — celui d'une petite filiale, d'un site distant — revient à compromettre la forêt entière, domaine racine compris. La véritable frontière de sécurité n'est pas le domaine : c'est la forêt. Un seul maillon faible, et il n'y a plus de cloison.

3

NIVEAU 3 — SUR LE TERRAIN

La salle des machines

Trois gestes, toujours dans le même ordre : **vérifier** vos approbations, **comprendre** ce qu'un attaquant en ferait, puis **corriger et détecter**.

1 Vérifier

Commençons par le diagnostic. Cette commande liste toutes les approbations du domaine, leur sens et leurs attributs — à exécuter depuis un poste disposant du module Active Directory (RSAT).

LA COMMANDE DU JOUR — INVENTORIER LES APPROBATIONS

```
PS C:\> Get-ADTrust -Filter * |
>> Select-Object Name, Direction, TrustType, IntraForest, SIDFilteringQuarantined
```

Mot à mot. **Direction** indique le sens (entrant, sortant, bidirectionnel) ; **IntraForest** dit si l'approbation reste dans la forêt ; **SIDFilteringQuarantined** révèle si le filtrage de SID est actif. **Une approbation entrante ou bidirectionnelle, sans filtrage, vers un domaine que vous n'administrez pas : voilà l'anomalie à traiter.**

Administrateur : Windows PowerShell

```
PS C:\> Get-ADTrust -Filter * | Select Name, Direction ...
```

Name	Direction	SIDFilteringQuarantined
partenaire.lab	BiDirectional	True
ancien-projet.lab	BiDirectional	False

```
PS C:\>
```

! L'anomalie

partenaire.lab est filtré (True) : protégé.

ancien-projet.lab ne l'est pas — bidirectionnel, ouvert.

Capture simulée — l'inventaire sur adcompagnon.lab : une approbation oubliée, sans filtrage de SID.

2 Comprendre l'attaque

Une approbation sans filtrage n'est pas une faille isolée : c'est un couloir. Voici comment un attaquant le franchit — depuis le domaine d'en face.

CE QU'UN ATTAQUANT EN FAIT

1 La tête de pont

Il compromet le domaine le plus faible — la petite filiale, le domaine partenaire mal tenu — et y obtient les droits d'administration. **BloodHound** cartographie d'emblée les approbations exploitables.

2 La clé d'approbation

Maître du domaine A, il en extrait la clé du compte de confiance inter-domaine — un **DCSync** ciblé sur ce compte suffit. Cette clé lui permet de forger des tickets que B acceptera.

3 Le ticket inter-royaume forgé

Avec **mimikatz** ou **Rubeus**, il fabrique un TGT inter-royaume et y injecte, dans le SID History, le SID des « Admins du domaine » de B.

4 La traversée

Il présente le ticket à B. Sans filtrage de SID, B honore le SID injecté : l'attaquant est administrateur du domaine B sans avoir jamais attaqué son périmètre.

Le couloir, c'est l'approbation sans filtrage. **Activez le filtrage, ou retirez l'approbation, et la traversée échoue.**

3 Corriger et détecter

La correction tient en trois gestes. Le premier fait le tri, le deuxième referme les ponts qui restent, le troisième surveille la traversée.

1 Inventorier et élaguer

Dressez la liste de toutes les approbations, et retirez sans état d'âme celles qui ne servent plus aucun usage métier — les approbations « historiques » sont presque toujours dans ce cas. La porte la plus sûre est celle qui n'existe pas.

2 Activer le filtrage de SID

Sur chaque approbation qui doit subsister, vérifiez et activez le filtrage de SID (quarantaine). Le SID History légitime d'une vraie migration en cours est rare ; partout ailleurs, le filtrage doit être la norme.

ACTIVER LE FILTRAGE DE SID SUR UNE APPROBATION

```
PS C:\> netdom trust adcompagnon.lab /domain:ancien-projet.lab `
>> /quarantine:Yes
```

3 Traiter le voisin comme soi-même

Pour les approbations qui restent, la sécurité du domaine partenaire devient la vôtre. Exigez d'en connaître le niveau de durcissement — ou considérez-le comme non fiable, et cloisonnez les accès qu'il permet en conséquence.

Détecter — les bons événements

Une traversée d'approbation laisse des traces sur les contrôleurs de domaine. Surveillez deux événements.

ID 4769 « Un ticket de service Kerberos a été demandé ». Une demande dont le compte provient d'un domaine approuvé, visant une ressource sensible, mérite l'examen — surtout si le compte source est inconnu de vos référentiels.

ID 4768 « Un ticket d'authentification Kerberos (TGT) a été demandé ». Croisé avec un identifiant venu de l'autre domaine, il aide à reconstituer un accès inter-royaume — et à repérer un SID privilégié là où il n'a rien à faire.

Pour une **chasse proactive**, ce filtre isole les approbations hors forêt dépourvues de filtrage de SID :

CHASSE — APPROBATIONS SANS FILTRAGE DE SID

```
PS C:\> Get-ADTrust -Filter * |
>> Where-Object { -not $_.SIDFilteringQuarantined -and -not $_.IntraForest } |
>> Select-Object Name, Direction, TrustType
```

OBSERVATEUR D'ÉVÉNEMENTS — JOURNAL SÉCURITÉ

Event ID 4769

Compte demandeur : ANCIEN-PROJET\j.martin

Domaine du compte: ancien-projet.lab – domaine approuvé, hors référentiel

Service demandé : ressource sensible du domaine adcompagnon.lab

Approbation : sans filtrage de SID

! Accès inter-royaume depuis une approbation non filtrée — à corrélérer et investiguer.

VU SUR LE TERRAIN

Lors de l'audit d'un groupe constitué par croissance externe, l'équipe de sécurité avait durci le domaine principal avec soin. L'attaque n'est pourtant pas passée par lui. La cartographie a révélé une approbation bidirectionnelle, sans filtrage de SID, vers le domaine d'une petite société acquise des années plus tôt — un domaine d'une cinquantaine de comptes, sans administrateur dédié, oublié de tous les plans de sécurité. Il a suffi d'une demi-journée pour en prendre le contrôle, en extraire la clé d'approbation, forger un ticket inter-royaume et obtenir les droits d'administration du domaine principal. La forteresse n'avait pas été percée : on était entré par la dépendance dont elle avait, un jour, accepté de partager les clés.

LE COIN DU DÉCIDEUR

Le périmètre de sécurité de votre annuaire n'est pas celui que vous croyez. Il ne s'arrête pas à votre domaine : il englobe **tout domaine auquel une approbation vous relie**. Votre niveau de sécurité réel est celui du maillon le plus faible de cette chaîne — et ce maillon est souvent un domaine que vous n'administrez pas. La bonne question pour votre équipe n'est pas « notre domaine est-il bien protégé ? », mais « **connaissons-nous, et assumons-nous, chaque pont qui sort de notre forêt ?** ». Toute approbation sans usage métier démontrable est une dette à solder. Toute approbation conservée engage votre responsabilité sur la sécurité d'un tiers.

L'ÉNIGME DU COMPAGNON — N°06

L'équipe d'`adcompagnon.lab` inspecte une vieille approbation et se rassure : « elle est *sortante* — c'est nous qui faisons confiance à l'autre domaine, donc le risque est pour eux, pas pour nous ». **Pourquoi ce raisonnement est-il dangereusement faux ?**

LA RÉPONSE DU COMPAGNON

Parce que le sens d'une approbation et le sens de l'accès sont **inversés**. Une approbation « sortante » signifie que votre domaine fait confiance à l'autre — donc que les comptes de l'*autre* domaine peuvent s'authentifier et accéder à des ressources *chez vous*. Le « risque » n'est pas pour eux : il est pour vous. La direction **sortante** est précisément celle qui ouvre votre domaine aux utilisateurs d'en face. Une approbation bidirectionnelle cumule les deux sens. L'erreur de lecture vient du mot « confiance », qu'on associe à un don ; ici, faire confiance, c'est *ouvrir sa porte*. Et c'est exactement sur une approbation sortante, sans filtrage de SID, qu'un ticket inter-royaume forgé depuis l'autre domaine vient prendre pied chez vous.

LE GLOSSAIRE

Approbation — relation par laquelle un domaine accepte les authentications issues d'un autre.

Forêt — ensemble de domaines partageant une configuration commune ; la vraie frontière de sécurité.

Direction — sens d'une approbation : entrante, sortante ou bidirectionnelle.

Clé d'approbation — secret partagé entre deux domaines, dérivé du compte de confiance inter-domaine.

TGT inter-royaume — ticket Kerberos permettant de franchir une approbation entre deux domaines.

PAC — structure d'un ticket portant l'identité de l'utilisateur et la liste de ses SID.

SID — identifiant unique d'un compte ou d'un groupe.

SID History — attribut conservant les anciens SID d'un compte migré ; transporté dans le PAC.

Filtrage de SID — garde-fou écartant les SID étrangers au partenaire légitime d'une approbation.

DCSync — abus de la réplication AD pour extraire des secrets, dont les clés d'approbation.

Intra-forêt — se dit d'une approbation entre domaines d'une même forêt ; non filtrée par défaut.

Tier 0 — le niveau des actifs qui contrôlent l'annuaire ; le périmètre le plus protégé.



DANS LE PROCHAIN NUMÉRO

N°07 — La réplication : le couteau suisse d'administration qui copie aussi vos secrets

Comment un droit prévu pour synchroniser les contrôleurs de domaine livre, à qui le détient, tous les mots de passe.